

INFORME DE SEGURIDAD Y CALIDAD EN EL DESARROLLO DE SOFTWARE

Plan de pruebas del Sistema de Gestión Atlas
Evaluación Parcial N°1 – Informe semestral, iteración 1 (Forma A)

ISY1102 – Seguridad y Calidad en el Desarrollo de Software

Sección 004V

Duoc UC – Escuela de Informática y Telecomunicaciones

Integrantes

Elías Robinson Delgado Manríquez
Rolando Aldana

Carrera: Ingeniería en Informática
Docente: Johnnathan René Cubillos Flores
Fecha: 15 de septiembre de 2026

ÍNDICE

1. Introducción.....	3
1.1 Contexto del software.....	3
1.2 Clasificación del producto.....	3
1.3 Propósito del plan.....	3
1.4 Alcance.....	4
2. Criterios de calidad.....	5
2.1 Calidad del producto.....	5
2.2 Seguridad.....	5
2.3 Normativas.....	6
2.4 Observaciones a la ERS.....	6
3. Plan de pruebas.....	7
3.1 Estrategia de pruebas.....	7
3.2 Tipos de prueba.....	8
3.3 Criterios de aceptación.....	9
3.4 Herramientas utilizadas.....	10
3.5 Recursos y cronograma.....	10
4. Diseño de casos de prueba.....	12
5. Matriz de trazabilidad y cobertura.....	20
5.1 Matriz de trazabilidad.....	20
5.2 Cobertura.....	22
5.3 Coherencia y brechas.....	22
6. Conclusión.....	24
Referencias.....	25

1. Introducción

1.1 Contexto del software

Atlas es una plataforma web que CreaLab SpA está desarrollando para pymes chilenas. Sirve para registrar clientes, asociarles contratos con sus documentos y administrar qué usuarios de cada empresa pueden ver o modificar esa información. La ERS (versión 1.1) define dos roles internos, administrador y editor, y exige un registro de auditoría para las acciones críticas.

Técnicamente es una SPA en React 19 que consume una API REST hecha en Node.js con Express 4, sobre una base de datos PostgreSQL. La sesión se maneja con JWT de corta duración y refresh token, las contraseñas se guardan con bcrypt y toda la comunicación debe ir por TLS. Además, el sistema tiene que funcionar en computador, tablet y celular, y la ERS pide poner atención especial en usuarios adultos mayores.

1.2 Clasificación del producto

Para decidir qué probar primero clasificamos Atlas según los tres ejes vistos en clases:

Eje	Clasificación	Por qué (según la ERS)
Calidad	Sistema transaccional de gestión, criticidad media-alta	Operaciones CRUD sobre clientes y contratos, tiempos de respuesta definidos (NFR-PERF) y disponibilidad de 99,5 % (NFR-DIS-1)
Seguridad	Sistema multiempresa con datos personales y bancarios	Datos bancarios de clientes (2.2), control de acceso por rol (NFR-SEG-4) y cifrado en reposo (NFR-SEG-3)
Cumplimiento	Trata datos personales de terceros bajo ley chilena	NFR-SEG-8, auditoría (RF-6) y acceso restringido por empresa (RB-2)

En la práctica esto significa que no basta con que los formularios funcionen. Un error que deje a una empresa ver los clientes de otra es, al mismo tiempo, una falla funcional, un problema de seguridad y un incumplimiento de la normativa de datos personales.

1.3 Propósito del plan

Con este plan queremos dejar definido cómo se va a comprobar que Atlas cumple lo que promete la ERS antes de salir a producción. Los focos son:

- que las funciones esenciales (login, gestión de usuarios, clientes, contratos y auditoría) respondan como está especificado;
- que ninguna empresa pueda acceder a datos de otra y que el rol editor no pueda escribir;

- que los datos personales y bancarios estén protegidos en tránsito y en reposo;
- que el sistema cumpla los tiempos de respuesta y sea usable para adultos mayores;
- que quede evidencia suficiente para demostrar cumplimiento de la Ley 19.628 y la Ley 21.719.

1.4 Alcance

El plan cubre los requerimientos funcionales RF-1 a RF-6, las reglas de negocio RB-1 a RB-5 y los no funcionales de seguridad, rendimiento, usabilidad, disponibilidad y compatibilidad descritos en la sección 3 de la ERS.

Quedan fuera la infraestructura física del proveedor de hosting, el funcionamiento interno del servicio de correo (solo se prueba la integración) y cualquier auditoría legal formal, que le corresponde a un abogado y no al equipo de QA.

2. Criterios de calidad

En este capítulo definimos qué estándares debe cumplir Atlas. Cada criterio está amarrado a un requerimiento de la ERS para que después se pueda probar.

2.1 Calidad del producto

Usamos como referencia el modelo ISO/IEC 25010. No todas sus características pesan lo mismo en Atlas, así que nos enfocamos en las que la ERS define con algún umbral:

Característica	Qué esperamos de Atlas	Requerimiento	Cómo se mide
Adecuación funcional	CRUD, estados de contrato y roles funcionan correctamente	RF-1 a RF-6	Casos funcionales aprobados
Eficiencia de desempeño	Respuestas rápidas con carga normal	NFR-PERF-1 a 3	p95 < 300 ms, carga < 2 s, 200 usuarios
Usabilidad	Pantallas legibles y flujos claros para adultos mayores	NFR-USAB-1 a 4	SUS ≥ 70 y sin bloqueos
Confiabilidad	Disponibilidad y recuperación ante fallos	NFR-DIS-1, NFR-SEG-7	Uptime ≥ 99,5 %, respaldo restaurable
Compatibilidad	Funciona en los navegadores indicados	NFR-COMPAT-1 y 2	Sin defectos bloqueantes en la matriz de navegadores
Mantenibilidad	Cambios y migraciones sin romper lo existente	NFR-DIS-2	Regresión automatizada en cada integración

2.2 Seguridad

Aquí tomamos como base OWASP Top 10 (2021) y el nivel 2 de OWASP ASVS, que es el recomendado para aplicaciones con datos personales. Los criterios que aplican a Atlas son:

- **Protección de datos:** TLS en todas las comunicaciones y cifrado de los datos bancarios en la base de datos (NFR-SEG-1, NFR-SEG-3).
- **Control de acceso:** la autorización se valida en el backend según el rol y la empresa del usuario, no solo ocultando botones en la interfaz (NFR-SEG-4, RB-2, RB-4).
- **Autenticación:** contraseñas con bcrypt y política de 12 caracteres con complejidad; tokens JWT de corta vigencia que se invalidan al cerrar sesión (RF-1, NFR-SEG-2, NFR-SEG-9).
- **Manejo de errores:** mensajes entendibles para el usuario, sin mostrar trazas, consultas SQL ni detalles internos (NFR-USAB-3).
- **Integridad:** validación y saneamiento de entradas contra SQL Injection, XSS y CSRF (NFR-SEG-5), y registro de auditoría de las acciones críticas (RF-6.1, NFR-SEG-6).

2.3 Normativas

Norma	Por qué aplica a Atlas
Ley 19.628, protección de la vida privada	Atlas guarda nombres, contactos, RUT y datos bancarios de clientes
Ley 21.719, que moderniza la protección de datos (vigencia prevista para diciembre de 2026)	Exige seguridad, proporcionalidad y responsabilidad proactiva: hay que poder demostrar las medidas tomadas
Ley 21.663, marco de ciberseguridad	Atlas no es un operador de importancia vital, pero la usamos como guía de seguridad desde el diseño y gestión de incidentes
Ley 21.459, delitos informáticos	Refuerza la necesidad de impedir y registrar accesos no autorizados; el pentest solo se hace con autorización escrita
Ley 17.336, propiedad intelectual	El proyecto usa librerías de terceros, por lo que hay que revisar sus licencias
ISO/IEC 25010, ISO/IEC 27001:2022 e ISO/IEC/IEEE 29119	Modelo de calidad, controles de seguridad y estructura del proceso de pruebas
WCAG 2.1 nivel AA	Accesibilidad web, relevante por el público adulto mayor

2.4 Observaciones a la ERS

Al leer la ERS encontramos algunos puntos ambiguos o incompletos. Los dejamos anotados porque afectan los criterios de aceptación y deberían aclararse con CreaLab:

1. Se pide fuente de 12 px, lo que es poco para adultos mayores. Recomendamos al menos 16 px para el texto base.
2. El rol editor es "solo visualización", pero RF-4.1 dice que "los usuarios" pueden crear clientes. Asumimos que manda RB-4: solo el administrador escribe.
3. RF-5.2 no fija tamaño máximo de archivo. Proponemos 10 MB y validar el tipo real del archivo.
4. RF-5.4 menciona el estado "vence" sin decir desde cuántos días. Asumimos 30 días antes del término.
5. NFR-USAB habla de un "score de usabilidad mínimo aceptable" sin número. Proponemos SUS ≥ 70 .
6. No hay requerimientos sobre consentimiento, derechos de los titulares ni aviso de brechas, que la Ley 21.719 sí exige.

3. Plan de pruebas

3.1 Estrategia de pruebas

Enfoque

Proponemos un enfoque mixto basado en riesgo. Las pruebas que se repiten en cada cambio (unitarias, API, control de acceso, regresión, carga y análisis de seguridad automático) se automatizan y corren en integración continua. Las que necesitan criterio de una persona, como usabilidad con adultos mayores, accesibilidad con lector de pantalla, pruebas exploratorias y pentest manual, se hacen a mano.

También aplicamos *shift-left*: el análisis de código y de dependencias corre desde el primer commit, y no se deja la seguridad para el final. Esto va en la línea de la seguridad por diseño que plantea la Ley 21.663.

Etapas

Siguiendo ISO/IEC/IEEE 29119, el proceso tiene cinco etapas:

1. **Planificación:** análisis de la ERS, riesgos, alcance y este plan.
2. **Diseño:** casos de prueba, datos de prueba y matriz de trazabilidad.
3. **Preparación:** ambiente QA, datos ficticios, herramientas y pipeline.
4. **Ejecución:** unitarias → integración y API → sistema → no funcionales → seguridad → aceptación del cliente.
5. **Cierre:** revisión de criterios de salida e informe de resultados.

Priorización

La prioridad sale de cruzar probabilidad e impacto, dando más peso cuando hay datos personales o bancarios de por medio.

Prioridad	Riesgo	Requerimientos
P1	Una empresa ve datos de otra, o un editor logra modificar información	RB-2, RB-4, NFR-SEG-4
P1	Inyección SQL, XSS o CSRF	NFR-SEG-5
P1	Sesión que sigue válida después del logout o token manipulado	RF-1.2, NFR-SEG-9
P2	Estado de contrato mal calculado o CRUD con validaciones fallidas	RF-4, RF-5.4
P2	No se cumplen los tiempos de respuesta	NFR-PERF
P3	Barreras de usabilidad o diferencias entre navegadores	NFR-USAB, NFR-COMPAT

Criterios de entrada y salida

Para empezar a ejecutar necesitamos la ERS aprobada (con las dudas de la sección 2.4 resueltas o asumidas), el build desplegado en QA con TLS, las pruebas unitarias en verde, datos ficticios cargados y la autorización escrita para el pentest.

Damos por terminadas las pruebas cuando:

- el 100 % de los casos P1 está aprobado;
- no quedan defectos abiertos de severidad crítica o alta;
- OWASP ZAP y el pentest no reportan vulnerabilidades críticas ni altas;
- se cumplen los umbrales de NFR-PERF y el SUS es de 70 o más;
- el Product Owner aprueba el informe de resultados.

Si un defecto bloquea más del 30 % de los casos o aparece una vulnerabilidad que expone datos, se suspende la ejecución hasta corregirlo y se repite la regresión del módulo afectado.

3.2 Tipos de prueba

Pruebas funcionales

Verifican que Atlas haga lo que dice la ERS. Incluyen pruebas **unitarias** para la lógica aislada (cálculo del estado del contrato, validación de RUT, política de contraseñas), pruebas de **sistema** que recorren flujos completos desde la interfaz (registro, creación de empresa, alta de cliente y contrato) y pruebas de **regresión** que se repiten en cada cambio. Las reglas de negocio RB-1 a RB-5 se prueban aquí.

Pruebas de integración

Comprueban que frontend, API, base de datos y almacenamiento de documentos funcionen juntos. El ejemplo más claro es la carga de un documento: pasa por la API, se guarda en el storage interno, se referencia en PostgreSQL y genera un registro de auditoría (RF-5.2, RF-5.3, RF-6.1). Aquí también entra la colección Swagger/Postman de endpoints críticos que pide la sección 3.1.2 de la ERS.

Pruebas de seguridad

Son las de mayor prioridad por el tipo de datos que maneja Atlas. Contemplan análisis estático del código y de dependencias, escaneo dinámico de la aplicación en QA, pruebas de control de acceso (intentar escribir con un editor o pedir recursos de otra empresa cambiando el ID), pruebas de sesión y tokens, revisión de TLS y cifrado en reposo, y un pentest manual con checklist ASVS antes de producción.

Pruebas de rendimiento

Buscan demostrar los umbrales de NFR-PERF: menos de 300 ms en operaciones CRUD simples, carga de la página principal en menos de 2 s en red móvil y soporte para 200 usuarios concurrentes. Se hace una prueba de carga con la concurrencia esperada y una de estrés para ver dónde se degrada el sistema.

Pruebas de usabilidad y accesibilidad

Se hacen sesiones con 5 adultos mayores, como pide la ERS, midiendo tareas completadas, errores y el puntaje SUS. En paralelo se revisa la conformidad con WCAG 2.1 AA: contraste, etiquetas ARIA, navegación con teclado y tamaño de los controles táctiles.

Pruebas de compatibilidad

Se ejecutan los flujos principales en las dos últimas versiones de Chrome, Firefox, Safari y Edge, y en celular, tablet y escritorio (NFR-COMPAT-1 y 2).

3.3 Criterios de aceptación

Además del criterio propio de cada caso, un caso solo se aprueba si cumple estas condiciones generales:

Funcionales

- La operación se completa y los datos quedan bien guardados.
- Las validaciones existen también en el backend: una petición directa a la API con datos inválidos responde 400 o 422.
- Las eliminaciones son lógicas y piden confirmación.

No funcionales

- CRUD simples con p95 bajo 300 ms y página principal bajo 2 s.
- Tasa de error menor a 1 % con 200 usuarios concurrentes.
- Sin incumplimientos críticos de WCAG 2.1 AA.

Seguridad y reglas de negocio

- Un recurso sin autorización responde 401 o 403 sin revelar si existe.
- Ningún mensaje muestra contraseñas, tokens, trazas o SQL.
- Solo usuarios de la empresa ven sus datos, y el editor no puede crear, editar ni eliminar.

Los defectos se clasifican en crítico, alto, medio o bajo. Los críticos y altos bloquean la liberación; los medios y bajos se aceptan con fecha de corrección.

3.4 Herramientas utilizadas

Herramienta	Para qué la usamos
Jest y Supertest	Pruebas unitarias y de endpoints en Express; es lo estándar en Node.js
React Testing Library	Pruebas de componentes como formularios de login y clientes
Swagger + Postman/Newman	Colección de endpoints críticos que pide la ERS, ejecutable en el pipeline
Playwright	Flujos end-to-end en Chromium, Firefox y WebKit (Safari), con emulación móvil
BrowserStack	Pruebas en dispositivos reales (iPhone, iPad, Android)
k6	Pruebas de carga y estrés con umbrales configurables
Lighthouse	Tiempo de carga en móvil y auditoría básica de accesibilidad
axe DevTools y NVDA	Revisión WCAG automática y navegación con lector de pantalla
OWASP ZAP y Burp Suite	Escaneo dinámico y pruebas manuales de tokens, IDOR y CSRF
SonarQube / Semgrep y npm audit	Análisis estático del código y vulnerabilidades en dependencias
GitHub Actions	Ejecución automática de las pruebas en cada push
Jira	Registro y seguimiento de defectos

3.5 Recursos y cronograma

Recursos humanos

Un QA Lead que coordina y aprueba los criterios de salida; dos analistas QA que diseñan y ejecutan los casos; un ingeniero de automatización a cargo de los scripts; un analista de seguridad para el análisis y el pentest; un especialista UX para las pruebas con usuarios; los desarrolladores para corregir defectos, y el Product Owner de CreaLab para resolver dudas y aprobar. Para usabilidad se necesitan además 5 adultos mayores que participen de las sesiones.

Recursos técnicos y entornos

Node.js 20 LTS, las versiones del stack indicadas en la ERS y PostgreSQL. Navegadores Chrome, Firefox, Safari y Edge; notebooks con Windows y macOS, celulares Android e iPhone y tablets.

Trabajamos con cuatro ambientes: desarrollo para pruebas unitarias, integración continua para la regresión automática, QA como réplica de producción para el resto de las pruebas, y preproducción para la aceptación y la carga final. En ningún ambiente se usan datos reales de clientes, solo datos ficticios.

Cronograma

Semana	Actividades	Hito
1	Análisis de la ERS, riesgos y aprobación del plan	Plan aprobado
2	Casos, datos de prueba, ambiente QA y pipeline	Ambiente listo
3	Pruebas funcionales, de integración y de API	Casos P1 funcionales aprobados
4	Rendimiento, compatibilidad y sesiones de usabilidad	Informe de carga y SUS
5	Pruebas de seguridad y pentest	Sin hallazgos críticos
6	Reprueba, regresión, aceptación del cliente e informe	Aceptación formal

4. Diseño de casos de prueba

Diseñamos ocho casos que cubren los distintos tipos de requerimientos de la ERS: tres funcionales, tres de seguridad y dos no funcionales. Se priorizaron los riesgos P1 de la sección 3.1 y los requerimientos con umbrales medibles. Los demás requerimientos quedan cubiertos por las suites y actividades indicadas en la matriz del capítulo 5.

CP-01 – Inicio de sesión con credenciales válidas

ID	NOMBRE	REQUERIMIENTO
CP-01	Inicio de sesión con credenciales válidas	RF-1.1, NFR-SEG-1, NFR-SEG-2, NFR-SEG-9
DESCRIPCIÓN		
Verificar que un usuario registrado pueda ingresar con su nombre de usuario y contraseña, y que el sistema entregue un token de sesión válido por una conexión segura.		
PRECONDICIONES		
Usuario activo asociado a una empresa. Ambiente QA con certificado TLS.		
PASOS		
1. Abrir la página de login con http:// y revisar que redirija a https://. 2. Ingresar usuario y contraseña válidos y presionar "Ingresar". 3. Revisar la respuesta de POST /api/auth/login. 4. Revisar en la base de datos cómo está guardada la contraseña.		
RESULTADO ESPERADO		
Respuesta HTTP 200 con un JWT y un refresh token. El usuario llega al dashboard de su empresa. La respuesta no incluye datos sensibles.		
CRITERIO DE ACEPTACIÓN		
La conexión es HTTPS. El JWT tiene expiración de 15 minutos o menos. La respuesta tarda menos de 300 ms. La contraseña está guardada como hash bcrypt (prefijo \$2b\$).		
DATOS DE PRUEBA		
Usuario: admin.pyme01 / Contraseña: Atlas#Prueba2026		
TIPO DE PRUEBA		
Funcional (sistema y API)		

CP-02 – Rol editor sin permisos de escritura

ID	NOMBRE	REQUERIMIENTO
CP-02	Rol editor sin permisos de escritura	RF-3.2, RB-4, NFR-SEG-4
DESCRIPCIÓN		
Comprobar que un usuario con rol editor solo pueda ver información, incluso si intenta crear, modificar o eliminar llamando directamente a la API.		
PRECONDICIONES		
Usuario editor en la empresa A. Existen al menos un cliente y un contrato.		
PASOS		
1. Iniciar sesión como editor. 2. Revisar que la interfaz no muestre botones de crear, editar ni eliminar. 3. Con el token del editor, enviar POST /api/contratos. 4. Enviar PUT y DELETE sobre un cliente existente.		
RESULTADO ESPERADO		
Las peticiones de los pasos 3 y 4 responden HTTP 403 y no cambian nada en la base de datos.		
CRITERIO DE ACEPTACIÓN		
Ninguna operación de escritura funciona con el rol editor. El bloqueo ocurre en el backend y no depende solo de ocultar botones.		
DATOS DE PRUEBA		
Usuario: editor.pyme01. JSON de contrato válido para el POST.		
TIPO DE PRUEBA		
Seguridad (control de acceso)		

CP-03 – Aislamiento de datos entre empresas

ID	NOMBRE	REQUERIMIENTO
CP-03	Aislamiento de datos entre empresas	RB-2, NFR-SEG-4, NFR-SEG-8
DESCRIPCIÓN		
Confirmar que un administrador de una empresa no pueda ver ni modificar datos de otra empresa cambiando el identificador en la URL o en la petición.		
PRECONDICIONES		
Empresas A y B con clientes cargados. El administrador solo pertenece a la empresa A.		
PASOS		
1. Iniciar sesión como administrador de A. 2. Enviar GET /api/empresas/102/clients (empresa B). 3. Enviar GET sobre un cliente de B. 4. Enviar PUT sobre un contrato de B.		
RESULTADO ESPERADO		
Todas las peticiones responden 403 o 404 y no se muestra ningún dato de la empresa B.		
CRITERIO DE ACEPTACIÓN		
No se expone ningún dato personal o bancario de B, tanto con IDs correlativos como aleatorios. La evidencia se guarda como respaldo de cumplimiento de la Ley 19.628.		
DATOS DE PRUEBA		
ID empresa A = 101, ID empresa B = 102, ID cliente de B = 5530		
TIPO DE PRUEBA		
Seguridad (control de acceso) y cumplimiento normativo		

CP-04 – Creación, validación y eliminación lógica de un cliente

ID	NOMBRE	REQUERIMIENTO
CP-04	Creación, validación y eliminación lógica de un cliente	RF-4.1, RF-4.2, RF-4.3, RB-5, NFR-USAB-3
DESCRIPCIÓN		
Validar que el administrador pueda crear, listar y eliminar clientes, que los campos se validen y que la eliminación sea lógica y con confirmación.		
PRECONDICIONES		
Sesión iniciada como administrador.		
PASOS		
1. Crear un cliente con datos válidos. 2. Intentar crear otro con RUT inválido y teléfono con letras. 3. Buscar el cliente creado usando el filtro por nombre. 4. Eliminarlo y cancelar en la confirmación. 5. Eliminarlo de nuevo y confirmar. 6. Revisar el registro en la base de datos.		
RESULTADO ESPERADO		
El cliente válido se guarda y aparece en el listado. Los datos inválidos muestran un mensaje claro en cada campo. Al cancelar no se elimina; al confirmar desaparece del listado pero sigue en la base de datos marcado como eliminado.		
CRITERIO DE ACEPTACIÓN		
La API también rechaza los datos inválidos (HTTP 422). La paginación y el filtro funcionan. La eliminación no borra físicamente el registro.		
DATOS DE PRUEBA		
Válido: Comercial Ñuñoa Ltda., RUT 76.123.456-0, +56 9 8765 4321. Inválido: RUT 12.345.678-X, teléfono 98ab76.		
TIPO DE PRUEBA		
Funcional (sistema)		

CP-05 – Cálculo del estado de un contrato

ID	NOMBRE	REQUERIMIENTO
CP-05	Cálculo del estado de un contrato	RF-5.1, RF-5.4, RB-3
DESCRIPCIÓN		
Verificar que el estado del contrato (activo, por vencer o expirado) se calcule bien a partir de sus fechas, incluyendo los casos límite.		
PRECONDICIONES		
Cliente creado. Umbral de "por vencer" de 30 días (supuesto de la sección 2.4). Fecha del sistema fijada en 16/09/2026.		
PASOS		
1. Crear los contratos A, B, C y D con las fechas indicadas. 2. Revisar el estado en el listado y en el detalle. 3. Intentar asociar un contrato a un segundo cliente.		
RESULTADO ESPERADO		
A queda activo, B por vencer y C expirado. D se rechaza por fechas incoherentes. El paso 3 no se permite.		
CRITERIO DE ACEPTACIÓN		
Todas las combinaciones muestran el estado correcto, incluidos los límites. Un contrato pertenece a un solo cliente.		
DATOS DE PRUEBA		
A: 01/01/2026 al 31/12/2026. B: 01/01/2026 al 16/10/2026. C: 01/01/2026 al 15/09/2026. D: inicio 01/06/2026 y término 01/05/2026.		
TIPO DE PRUEBA		
Funcional (unitaria y sistema, valores límite)		

CP-06 – Protección contra inyección SQL, XSS y CSRF

ID	NOMBRE	REQUERIMIENTO
CP-06	Protección contra inyección SQL, XSS y CSRF	NFR-SEG-5, RF-4.3
DESCRIPCIÓN		
Comprobar que los formularios y endpoints rechacen o neutralicen entradas maliciosas comunes.		
PRECONDICIONES		
Autorización escrita para el pentest. Ambiente QA aislado con OWASP ZAP y Burp Suite configurados.		
PASOS		
1. Ingresar una carga de inyección SQL en el login y en el filtro de clientes. 2. Guardar un cliente con un script en la descripción y abrir su detalle. 3. Enviar una petición de modificación desde otro origen sin token CSRF. 4. Ejecutar un escaneo activo con OWASP ZAP.		
RESULTADO ESPERADO		
No se obtiene acceso ni se alteran datos. El script se muestra como texto y no se ejecuta. La petición externa es rechazada. Los errores no muestran información técnica.		
CRITERIO DE ACEPTACIÓN		
OWASP ZAP no reporta vulnerabilidades críticas ni altas. Las consultas son parametrizadas. Existen cabeceras CSP y CORS restrictivas.		
DATOS DE PRUEBA		
' OR '1'='1' -- ; <script>alert('xss')</script> ; 		
TIPO DE PRUEBA		
Seguridad (escaneo dinámico y pentest manual)		

CP-07 – Carga con 200 usuarios concurrentes

ID	NOMBRE	REQUERIMIENTO
CP-07	Carga con 200 usuarios concurrentes	NFR-PERF-1, NFR-PERF-2, NFR-PERF-3, NFR-DIS-1
DESCRIPCIÓN		
Medir tiempos de respuesta y tasa de error con la concurrencia que define la ERS.		
PRECONDICIONES		
Preproducción equivalente a producción, con 20.000 clientes y 50.000 contratos ficticios. Script de k6 revisado.		
PASOS		
1. Subir de 0 a 200 usuarios virtuales en 5 minutos. 2. Mantener 200 usuarios por 20 minutos haciendo login, listados, creación y edición de clientes. 3. Medir la página principal con Lighthouse en perfil móvil. 4. Registrar CPU, memoria y conexiones a la base de datos.		
RESULTADO ESPERADO		
Las operaciones CRUD simples responden con p95 bajo 300 ms, la página principal carga en menos de 2 s y el servicio no se cae.		
CRITERIO DE ACEPTACIÓN		
Tasa de error menor a 1 %. Los umbrales se cumplen en tres ejecuciones seguidas. Se adjuntan los reportes de k6 y Lighthouse.		
DATOS DE PRUEBA		
Script carga_atlas.js con 60 % lecturas y 40 % escrituras.		
TIPO DE PRUEBA		
No funcional (rendimiento)		

CP-08 – Usabilidad y accesibilidad con adultos mayores

ID	NOMBRE	REQUERIMIENTO
CP-08	Usabilidad y accesibilidad con adultos mayores	NFR-USAB-1, NFR-USAB-2, NFR-USAB-3, NFR-USAB-4
DESCRIPCIÓN		
Evaluar si personas mayores completan tareas habituales sin ayuda y si las pantallas principales cumplen WCAG 2.1 AA.		
PRECONDICIONES		
5 participantes de 60 años o más con consentimiento firmado. Datos ficticios. axe DevTools y NVDA instalados.		
PASOS		
1. Pedir a cada participante buscar un cliente y abrir sus contratos. 2. Pedir crear un cliente cometiendo un error y luego corregirlo. 3. Anotar tiempo, errores y veces que pide ayuda. 4. Aplicar el cuestionario SUS. 5. Revisar las pantallas con axe y recorrerlas solo con teclado y NVDA.		
RESULTADO ESPERADO		
Los participantes completan las tareas sin bloqueos, entienden los mensajes de error y siguen el flujo cliente → contratos.		
CRITERIO DE ACEPTACIÓN		
Al menos 80 % de las tareas completadas sin ayuda. SUS de 70 o más. Contraste mínimo 4,5:1 y controles táctiles de 44 × 44 px o más. Sin errores críticos en axe.		
DATOS DE PRUEBA		
Guion de 3 tareas y cuestionario SUS de 10 preguntas.		
TIPO DE PRUEBA		
No funcional (usabilidad y accesibilidad)		

5. Matriz de trazabilidad y cobertura

5.1 Matriz de trazabilidad

La matriz relaciona cada requerimiento de la ERS con el caso de prueba que lo verifica, el tipo de prueba y la norma o estándar asociado. Cuando todavía no hay un caso detallado, se indica la suite o actividad que lo cubre; esos casos se van a redactar en la iteración 2. La misma matriz está en formato CSV en la carpeta anexos del repositorio.

Requerimiento	Descripción	Caso o actividad	Tipo de prueba	Norma o estándar
RF-1.1	Autenticación con usuario y contraseña	CP-01	Funcional	OWASP A07
RF-1.2	Cierre de sesión y revocación de tokens	Suite de API (sesión)	Seguridad	OWASP A07
RF-2.1	Registro de usuario	Suite end-to-end	Funcional	Ley 21.719
RF-2.2	Creación de empresa	Suite end-to-end	Funcional	ISO/IEC 25010
RF-2.3	Primer usuario como administrador	Suite end-to-end	Funcional	ISO/IEC 27001
RF-3.1	Invitar o crear usuarios con rol	Suite de API	Funcional	ISO/IEC 27001
RF-3.2	Editor solo visualiza	CP-02	Seguridad	OWASP A01
RF-3.3	Modificar o eliminar usuarios	Suite de API	Funcional	ISO/IEC 27001
RF-4.1	Crear clientes	CP-04	Funcional	ISO/IEC 25010
RF-4.2	Editar, eliminar y listar clientes	CP-04	Funcional	Ley 19.628
RF-4.3	Validación de campos	CP-04, CP-06	Funcional y seguridad	OWASP A03
RF-5.1	Crear contratos por cliente	CP-05	Funcional	ISO/IEC 25010
RF-5.2	Adjuntar documentos	Suite de integración	Integración	OWASP A04
RF-5.3	Documentos en storage interno	Suite de integración	Integración	ISO/IEC 27001
RF-5.4	Estado del contrato por fechas	CP-05	Funcional	ISO/IEC 25010
RF-5.5	Enlace para compartir documento	Prueba de seguridad planificada	Seguridad	OWASP A01, Ley 19.628
RF-6.1	Auditoría de acciones críticas	Suite de integración	Funcional	OWASP A09, Ley 21.719

Requerimiento	Descripción	Caso o actividad	Tipo de prueba	Norma o estándar
RB-1	Correo principal único	Suite end-to-end	Regla de negocio	Integridad de datos
RB-2	Acceso solo a usuarios de la empresa	CP-03	Seguridad	Ley 19.628, OWASP A01
RB-3	Contrato asociado a un cliente	CP-05	Regla de negocio	Integridad de datos
RB-4	Editor solo lectura	CP-02	Seguridad	OWASP A01
RB-5	Administrador con acceso completo	CP-04	Funcional	Mínimo privilegio
NFR-SEG-1	TLS obligatorio	CP-01	Seguridad	OWASP A02
NFR-SEG-2	Contraseñas con bcrypt	CP-01	Seguridad	OWASP A02
NFR-SEG-3	Cifrado de datos sensibles en reposo	Revisión de base de datos en QA	Seguridad	Ley 19.628, ISO/IEC 27001
NFR-SEG-4	Control de acceso por rol en backend	CP-02, CP-03	Seguridad	OWASP A01
NFR-SEG-5	Protección contra CSRF, XSS y SQLi	CP-06	Seguridad	OWASP A03
NFR-SEG-6	Gestión segura de logs	Revisión de logs	Seguridad	OWASP A09
NFR-SEG-7	Respaldo y recuperación	Prueba de restauración	Confiabilidad	ISO/IEC 27001
NFR-SEG-8	Cumplimiento de protección de datos	CP-03	Cumplimiento	Ley 19.628, Ley 21.719
NFR-SEG-9	Sesión con JWT	CP-01	Seguridad	OWASP A07
NFR-PERF-1	CRUD bajo 300 ms	CP-07	Rendimiento	ISO/IEC 25010
NFR-PERF-2	Página principal bajo 2 s en móvil	CP-07	Rendimiento	ISO/IEC 25010
NFR-PERF-3	200 usuarios concurrentes	CP-07	Rendimiento	ISO/IEC 25010
NFR-USAB-1	Tipografía, contraste y controles grandes	CP-08	Usabilidad	WCAG 2.1 AA
NFR-USAB-2	Flujos claros de registro	CP-08	Usabilidad	ISO/IEC 25010
NFR-USAB-3	Ayuda y errores amigables	CP-04, CP-08	Usabilidad	WCAG 2.1 AA
NFR-USAB-4	Flujo cliente → contratos	CP-08	Usabilidad	ISO/IEC 25010
NFR-DIS-1	Disponibilidad de 99,5 %	CP-07 y monitoreo	Confiabilidad	ISO/IEC 25010

Requerimiento	Descripción	Caso o actividad	Tipo de prueba	Norma o estándar
NFR-DIS-2	Mantenimiento y migración segura	Prueba de migración	Mantenibilidad	ISO/IEC 27001
NFR-COMPAT-1	Navegadores modernos	Suite Playwright multi-navegador	Compatibilidad	ISO/IEC 25010
NFR-COMPAT-2	Responsivo en móvil y tablet	Suite Playwright y BrowserStack	Compatibilidad	ISO/IEC 25010

5.2 Cobertura

La ERS tiene 42 requerimientos entre funcionales, reglas de negocio y no funcionales. Todos quedan trazados a una prueba. De ellos, 25 (60 %) tienen un caso detallado en este informe y los 17 restantes están cubiertos por una suite o actividad planificada.

Grupo	Total	Con caso detallado	Con actividad planificada
Funcionales (RF)	17	7	10
Reglas de negocio (RB)	5	4	1
Seguridad (NFR-SEG)	9	6	3
Rendimiento (NFR-PERF)	3	3	0
Usabilidad (NFR-USAB)	4	4	0
Disponibilidad (NFR-DIS)	2	1	1
Compatibilidad (NFR-COMPAT)	2	0	2
Total	42	25	17

El porcentaje de casos detallados es menor en los requerimientos funcionales porque priorizamos lo que tiene más riesgo. Los riesgos P1 de la sección 3.1 (acceso entre empresas, permisos del editor e inyección) sí tienen caso propio. En cambio, flujos como el registro o la gestión de usuarios se cubren con la suite end-to-end, que no requiere un caso manual por separado.

5.3 Coherencia y brechas

Al revisar el plan completo vemos que es coherente con los objetivos de la sección 1.3: los permisos del editor se prueban en CP-02, el aislamiento entre empresas en CP-03, la protección de datos en CP-01 y CP-06, el rendimiento en CP-07 y la experiencia de adultos mayores en CP-08. De OWASP Top 10 quedan cubiertas con casos A01, A02, A03 y A07. A06 (componentes vulnerables) se controla con npm audit en el pipeline y A09 (registro y monitoreo) con la revisión de logs y auditoría planificada.

Las brechas que quedan para la siguiente iteración son:

- redactar los casos de sesión (RF-1.2), enlaces compartidos (RF-5.5), cifrado en reposo (NFR-SEG-3), respaldo (NFR-SEG-7) y compatibilidad (NFR-COMPAT);
- validar con CreaLab los supuestos de la sección 2.4 (tamaño de archivo, umbral de 30 días y $SUS \geq 70$);
- proponer requerimientos de consentimiento, derechos de los titulares y aviso de brechas, que la Ley 21.719 exige y la ERS no incluye.

6. Conclusión

Atlas maneja datos personales y bancarios de clientes de distintas empresas en una misma plataforma. Por eso el plan pone el mayor esfuerzo en el control de acceso y la protección de datos, sin dejar de lado el rendimiento ni la usabilidad para adultos mayores, que la ERS marca como prioridades.

El enfoque mixto permite automatizar lo que se repite en cada versión y reservar el trabajo manual para lo que necesita criterio humano. La matriz de trazabilidad deja cada requerimiento conectado a una prueba y a una norma, lo que sirve tanto para encontrar defectos como para demostrar cumplimiento frente a la Ley 19.628 y la Ley 21.719.

Durante el análisis también encontramos vacíos en la propia ERS: umbrales sin definir, una contradicción en los permisos del editor y la ausencia de requerimientos de consentimiento y aviso de brechas. Los dejamos documentados para trabajarlos en la siguiente iteración del caso semestral.

Referencias

- Biblioteca del Congreso Nacional de Chile. (1970). *Ley 17.336 sobre propiedad intelectual*.
- Biblioteca del Congreso Nacional de Chile. (1999). *Ley 19.628 sobre protección de la vida privada*.
- Biblioteca del Congreso Nacional de Chile. (2022). *Ley 21.459 que establece normas sobre delitos informáticos*.
- Biblioteca del Congreso Nacional de Chile. (2024). *Ley 21.663 marco de ciberseguridad*.
- Biblioteca del Congreso Nacional de Chile. (2024). *Ley 21.719 que regula la protección y el tratamiento de los datos personales*.
- CreaLab SpA. (2026). *Especificación de requerimientos de software: Sistema de Gestión Atlas (v1.1)*.
- ISO/IEC. (2023). *ISO/IEC 25010: Systems and software quality requirements and evaluation (SQuaRE) – Product quality model*.
- ISO/IEC. (2022). *ISO/IEC 27001: Information security management systems – Requirements*.
- ISO/IEC/IEEE. (2022). *ISO/IEC/IEEE 29119: Software and systems engineering – Software testing*.
- OWASP Foundation. (2021). *OWASP Top 10*.
- OWASP Foundation. (2021). *Application Security Verification Standard 4.0.3*.
- W3C. (2018). *Web Content Accessibility Guidelines (WCAG) 2.1*.